AI AGENTS, MCP & APIS FOR PMS AND BAS · LESSON 1 OF 6

APIs Without Code: How Apps Talk, REST, JSON, Authentication, Webhooks and Postman for PMs and BAs

Understand APIs well enough to write requirements, read documentation, test endpoints and design integrations without writing code. Learn requests and responses, REST verbs and status codes, JSON, authentication (API keys, OAuth 2.0), rate limits and pagination, webhooks vs polling, and how to try any API in Postman, then turn it into a PRD-ready integration spec.

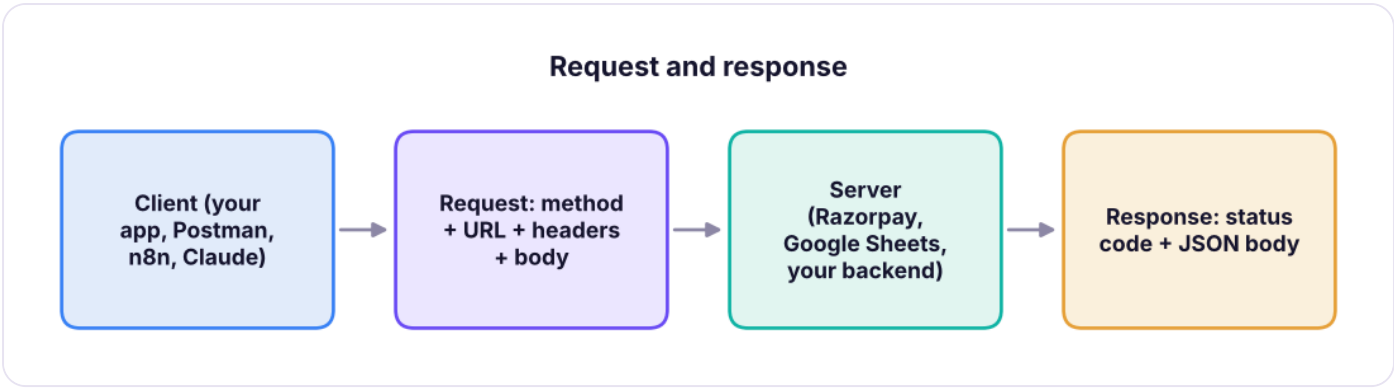
✦ 2026 | Beginner | ⏱ 120 min

By the end of this lesson you can

- Explain what an API, an endpoint, a request and a response are, with real examples
- Read API documentation and JSON, and know what each HTTP method and status code means
- Choose between API keys and OAuth, and between webhooks and polling
- Test an API in Postman without code and save a collection for your team
- Write an integration section of a PRD with data mapping, errors and limits

What an API is

An **API** (Application Programming Interface) is a contract that lets one app ask another for data or actions. When the Swiggy app shows a restaurant's live wait time, it calls an API; when Zomato sends you an SMS, it calls an SMS provider's API; when your payment goes through, the app calls Razorpay's API.



Every API call is a request and a response.

The parts of a request

Part	Example	Meaning
Method	`GET`, `POST`, `PUT` / `PATCH`, `DELETE`	Read, create, update, delete
Base URL + path (endpoint)	`https://api.example.com/v1/orders/123`	Which resource
Query parameters	`?status=paid&limit=20`	Filters, sorting, paging
Headers	`Authorization: Bearer sk_live_…`, `Content-Type: application/json`	Who you are, what format
Body	`{"amount": 49900, "currency": "INR"}`	Data you send (POST/PUT/PATCH)

Status codes every PM should know

Code	Meaning	What to put in the PRD
200 OK / 201 Created	Success	Show the result / confirmation
400 Bad Request	Invalid input	Field-level validation message
401 Unauthorized / 403 Forbidden	Not logged in / not allowed	Ask to log in / hide the action
404 Not Found	Resource does not exist	Friendly empty state
409 Conflict	Duplicate or version clash	"Already exists" handling
429 Too Many Requests	Rate limit hit	Retry later, queue, back-off
500 / 502 / 503	Server problem	Retry with back-off, show status, alert on-call

JSON: the language of APIs

Python

```python
import json
response = '''{"order_id": "ORD-1029", "status": "paid", "amount": {"value": 49900,
"currency": "INR"},
 "customer": {"name": "Asha Rao", "city": "Pune"}, "items": [{"sku": "TSHIRT-M", "qty": 2},
{"sku": "CAP", "qty": 1}]}'''
order = json.loads(response)
print("Status:", order["status"])
print("Amount in rupees:", order["amount"]["value"] / 100)          # amounts often come in
paise
print("Items:", [f'{i["sku"]} x{i["qty"]}' for i in order["items"]])
```

OUTPUT

```
Status: paid
Amount in rupees: 499.0
Items: ['TSHIRT-M x2', 'CAP x1']
```

Read JSON like a tree: `{ }` is an object (named fields), `[ ]` is a list. `order.amount.value` is a path into the tree; tools like n8n, Make and Zapier let you click that path instead of typing it.

Authentication

Method	How it works	Typical use
API key	A secret string in a header	Server-to-server, internal tools
Bearer token	A token in `Authorization: Bearer …`	Most modern APIs
OAuth 2.0	User clicks "Allow"; the app gets a scoped, expiring token	"Sign in with Google", Gmail/Slack integrations
Webhook signature	The sender signs each event with a shared secret	Verifying Razorpay/Stripe/GitHub events

> **WATCH OUT** **Never share or paste live keys**
>
> Keys belong in a secrets manager or the tool's credential store, never in documents, screenshots, chats or client-side code. Rotate a key immediately if it leaks.

Rate limits, pagination and idempotency

- **Rate limits**: e.g. 100 requests per minute; plan batches and back-off.
- **Pagination**: results arrive in pages (`page=2` , `cursor=abc` , a `next` link); integrations must follow every page.
- **Idempotency**: payment APIs accept an `Idempotency-Key` so a retried request does not charge twice.

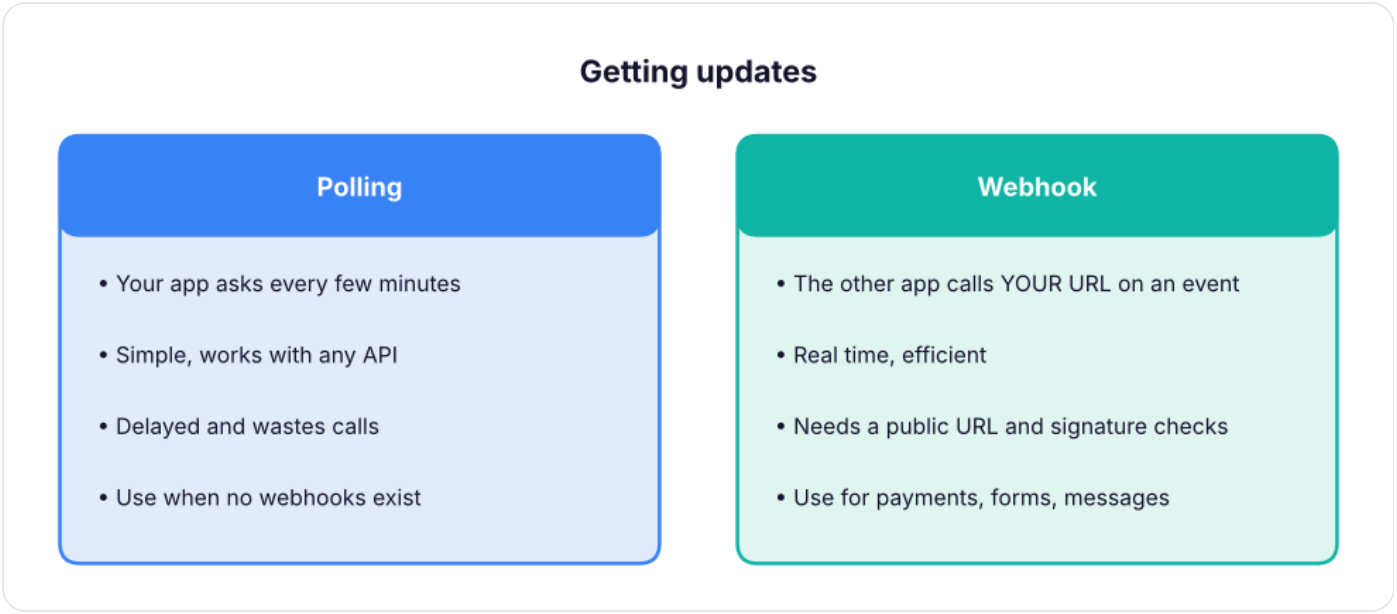
Python

```python
import math
records, page_size, limit_per_min = 12_500, 100, 60
calls = math.ceil(records / page_size)
print(f"{calls} calls needed; at {limit_per_min}/min the first full sync takes about
{math.ceil(calls / limit_per_min)} minutes")
```

OUTPUT

```
125 calls needed; at 60/min the first full sync takes about 3 minutes
```

Webhooks vs polling



Polling asks again and again; a webhook tells you when something happens.

Try an API in Postman (no code)

STEP BY STEP **Your first request**

1. Install Postman (or use the web app) and create a free workspace.
2. New → HTTP request. Method `GET`, URL `https://api.github.com/repos/n8n-io/n8n`.
3. Send. Read the status (200), time and the JSON body: `stargazers_count`, `forks_count`.
4. Save it to a **collection**; add an **environment** with variables such as `{{base_url}}` and `{{token}}`.
5. Try a `POST` against a test API (for example a sandbox from your payment provider) with a JSON body, and read the 201 or 400 responses.
6. Use **Code** (the `</>` icon) to see the same call as cURL: you can paste cURL into n8n's HTTP Request node.

Other free ways to explore APIs: the browser address bar for simple GETs, **Hoppscotch**, the **Swagger/OpenAPI** "Try it out" pages many APIs publish, and asking Claude to explain an API reference page.

Writing the integration section of a PRD

Section	What to write
Goal	"Create a Freshdesk ticket when a premium customer submits a complaint form"
Systems and endpoints	Form webhook → `POST /api/v2/tickets`
Data mapping	form.email → requester_email; form.issue → description; plan → tag
Auth	Freshdesk API key stored in the integration platform's credentials
Triggers and timing	On submit (webhook), under 1 minute
Errors and retries	3 retries with back-off; on failure alert #support-ops
Limits	1,000 calls/hour; expected 200/day
Security and privacy	No card data; mask phone numbers in logs; DPDP consent captured on the form
Acceptance criteria	Ticket created with correct fields in 95% of tests; duplicates prevented by form ID

Summary

KEY TAKEAWAYS

- An API call is a method + URL + headers + body; the answer is a status code + JSON.
- Know the common status codes and what the user should see for each.
- Use API keys or OAuth, respect rate limits, follow pagination and use idempotency for payments.
- Prefer webhooks for real-time events; test everything in Postman before you spec it.

Quick quiz

6 questions · tap an answer to check it

1. Which method creates a new record?

- **A** POST
- **B** GET
- **C** DELETE
- **D** HEAD

Answer: A. GET reads; POST creates; PUT/PATCH update; DELETE removes.

2. An integration receives 429 responses. What does it mean?

- **A** The rate limit was exceeded; slow down and retry later
- **B** The record was not found
- **C** The login is wrong
- **D** Success

Answer: A. Add back-off and batching.

3. Which authentication lets a user grant an app scoped access to their Gmail?

- **A** OAuth 2.0
- **B** A shared password in the PRD
- **C** No authentication
- **D** Basic auth with the admin password

Answer: A. OAuth gives scoped, revocable tokens.

4. When is a webhook better than polling?

A When you need real-time updates about events such as payments

B When the API has no webhooks

C When you want more API calls

D Never

Answer: A. Webhooks push events to your URL.

5. Why do payment APIs support idempotency keys?

A So a retried request does not create a duplicate charge

B To speed up responses

C To encrypt the body

D To bypass rate limits

Answer: A. Retries are safe with the same key.

6. In JSON, what does [ ] represent?

A A list (array)

B An object

C A comment

D A string

Answer: A. { } is an object.

EXERCISE **Practice**

Pick a public API (GitHub, a weather API or your company's sandbox). In Postman, save three requests (one GET with a query parameter, one POST, one that returns an error) in a collection. Then write the integration section of a PRD for "send a WhatsApp confirmation when an order is paid" using the table above.

Show solution (worked answer)

A good answer names the trigger (payment webhook), the endpoint of the WhatsApp provider, a data mapping table, credentials storage, retry and alert rules, the rate limit, the template approval requirement for WhatsApp business messages, consent, and testable acceptance criteria.

INTERVIEW CORNER **Questions you may be asked**

Q: Explain an API to a non-technical stakeholder. It is a menu and a waiter: the menu (documentation) lists what you can ask for, you place an order (request), and the kitchen (server) returns your dish (response) or a reason it cannot.

Q: REST vs webhooks? REST is request-response: you ask when you want data. Webhooks are event notifications: the other system calls you when something happens.

Q: What would you check before committing to a third-party API? Coverage of the needed endpoints, authentication, rate limits and pricing, uptime/SLA and status page, webhooks, sandbox, data residency and privacy, versioning and deprecation policy, and support.

Q: How do you write acceptance criteria for an integration? Specify the trigger, the exact data mapping, success latency, error handling and retries, duplicates, logging, and measurable pass conditions in test and production.

Q: What is OpenAPI? A standard machine-readable description of a REST API (endpoints, parameters, schemas) used to generate docs, test pages, SDKs and tool definitions for AI agents.

Learn more

- Postman Academy (free)
- MDN: HTTP overview
- OpenAPI introduction

Practise more online

Free, trusted places to test yourself on this topic. Links open the original site in a new tab.